

ESP32-S3 · firmware 5.5.6 · SX1280 + SX126x (inferred) · packet-demod detector · OTA over TLS

Executive summary

The **Tsukorok** (Цукорок, internal name `cukorok`) is a Ukrainian handheld passive drone detector by Drone Spices Ltd. A physical unit was connected over USB and characterised without opening the case or modifying firmware. We fully recovered the device's **command interface, live RF detection configuration, detection model, and over-the-air (OTA) update architecture**.

We did **not** obtain the firmware binary: the OTA transfer is protected by TLS and cannot be extracted by passive capture. Whether it can be extracted by *active* TLS interception is **untested and unresolved** (see §5). The recovered RF parameters are directly useful to AERIX RF — they show which sub-GHz drone-telemetry links a fielded detector keys on, and at what rates.

1 · Device identification

Property	Value
Product	Tsukorok / Цукорок drone detector
Vendor	Drone Spices Ltd (UA / London)
USB ID	303a:1001 — Espressif ESP32-S3 (USB-Serial-JTAG)
Internal name / HW rev	cukorok / tsukorok-S3-V4
Firmware / device id	5.5.6 / 2008937968
MAC / serial	F0:F5:BD:77:18:70
Radio (inferred)	SX1280 (2.4 GHz FLRC) + SX126x (sub-GHz LoRa/GFSK)
Sensitivity / bands (vendor)	−132 dBm · 720–1020 MHz, 2.4–2.5 GHz

FLRC support and −132 dBm sensitivity are the fingerprints pointing to a Semtech SX1280 + SX126x pair rather than a wideband SDR.

2 · Method

- **USB console** — text command console over CDC-ACM (115200 8N1); vendor manual + safe word-probing of 5.5.6.
- **OTA capture** — host laptop became the AP the device seeks (`drone_spices / 87654321`), with wildcard DNS + passive packet capture and **no route to the internet** ("log-only"); device driven to update via USB.

No firmware was flashed; no device setting intentionally changed. One probe transiently cleared the scan ranges — caught by before/after diff and immediately restored.

3 · Live RF detection configuration (read off the unit — CONFIRMED)

```
current_mode      = normal (3)          rssi_threshold = 94
freq_ranges       = 860-885 MHz | 895-928 MHz | 970-1020 MHz
bitrates          = [57600, 80000, 15235, 0] (G)FSK symbol rates
spreading_factors = [9, 8, 0, 0]         LoRa SFs
preamble_size     = 16                   tracking = off
alarm timings     = fsk[500,2500,1] lora[400,1000,1] rssi[500,2700,1] tracking[300,750,1]
```

Interpretation (strong inference): the detector is a **packet-radio demodulator bank**, not a spectral/energy classifier. It parks GFSK and LoRa receivers on specific, measured drone telemetry/control-link parameters across three sub-GHz windows and alarms on RSSI. The oddly specific bitrates — especially 15235 bps — are measured signatures of particular drone links, functionally a target list. upload captures ships signatures back to the vendor → crowd-sourced signature DB.

4 · OTA update architecture (packet-captured — CONFIRMED)

1. **Time gate first.** Resolves pool.ntp.org / time.nist.gov, does SNTP (:123). Without a valid clock it aborts before any firmware request.
2. **HTTPS to dev.drone-spices.com:443** — ClientHello SNI = dev.drone-spices.com. Note: a **dev / staging** channel.
3. Firmware GET + transfer occur **inside** TLS.

Backend host (from cert SAN)	Role
dev.drone-spices.com	OTA endpoint + staging site
terminal.drone-spices.com	browser Web-Serial console (same command interface)
landing.drone-spices.com	product landing page
tsukorok.drone-spices.com	public product page

5 · Can the firmware be pulled from the traffic?

Passive capture (Wireshark / port mirror): No.

The transfer is inside TLS with ephemeral-key (ECDHE / forward-secrecy) session keys. Captured traffic is ciphertext and cannot be decrypted *even with the server's private key*. Mirroring is a dead end for the binary.

Active TLS interception (mitmproxy): Unresolved — one test decides it.

Terminating TLS with our own certificate would expose the plaintext OTA URL and firmware *if the device does not validate the certificate chain*. This was **not** tested: the log-only endpoint never presented a certificate (it closed the socket after the ClientHello), so the device's abort

proves only that it needs a real TLS responder — **not** that it checks the signer. Many ESP OTA builds, especially dev channels, skip validation.

device completes handshake -> not validating -> firmware recoverable in cleartext
device rejects our cert -> validating/pinned -> only the hardware route remains

6 · Routes to the firmware binary — status

Route	Status
Passive traffic capture	✗ ruled out — TLS forward secrecy
Active TLS intercept (mitmproxy)	? untested — recommended next experiment
Public OTA path on server	✗ not publicly served; not blindly enumerated (vendor dev server)
Web flasher (serial.html / terminal)	✗ Web-Serial console only, no firmware fetch
Hardware flash dump (BOOT→GPIO0)	? 6 attempts booted app; verify pad = GPIO0, else likely DIS_DOWNLOAD_MODE fused
Ask vendor (t.me/drone_spices_bot)	✓ clean legitimate route to an official image

7 · Relevance to AERIX RF

- The sub-GHz windows, GFSK bitrates (57600 / 80000 / 15235) and LoRa SFs (9 / 8) are concrete, reusable parameters for our own **passive** detection of the same drone-telemetry link classes.
- Architecture contrast: a cheap fixed-parameter demod bank vs. AERIX RF's wideband ANTSDR/HackRF capture + analysis.
- **Evidence discipline:** these are RF-candidate / protocol-morphology level, *not* validated decodes — they show what a commercial detector keys on, not confirmed drone identities.

8 · Safety / integrity

Operator-owned device; passive analysis only — no transmit, jamming, spoofing or takeover. No exploitation of vendor infrastructure; public recon was minimal and stopped short of enumeration. The one accidental config change (scan ranges) was fully restored and verified by diff.

9 · Firmware obtained & analysed (v5.5.12 — pulled via operator-run TLS intercept)

How: the device does **not** validate the OTA server certificate (plain Arduino OTA, no secure-boot / flash-encryption). Active TLS interception on the operator's own network exposed the OTA call — a JSON POST to /detector-server/activation/upgrade with a **hard-coded static bearer token** — whose reply is a pre-signed AWS S3 URL to the image. Image: tsukor_s3v4_5.5.12_en.bin, 1,182,928 B, valid ESP32-S3 app, Arduino-ESP32 / ESP-IDF v4.4.7. Sensitive values (token, S3 key-id) kept local, not in the repo. Device was NOT flashed.

Detection engine (RadioLib-style + A5133 sub-GHz path)

Target	Method (firmware evidence)
DJI	"paranoid scan", 5.8 GHz, signal-width + RSSI (dji_alg, dji_sig_width, dji_qblock, dji_scan2)
Zala / ZalaLancet	SX1280 2.4 GHz video scan, signal-history accumulator
Orlan / Orlan+S / "Cryptoorlan"	syncword-based (cryptoorlan: adding syncword %x at %dmhz) + syncword-count detector
ELRS	spreading-factor based (elrs24, ELRS freq/sf/rssi)
Eleron, FPV	dedicated detection paths

Tunable NVS keys: freq1_start..freq3_end, bitrate_first..forth, alarm_{lora,prmb, rssi, track}_{cnt, frq, len}, fsk_config, dji_*.

Notable capability — **ATAK** / **Cursor-on-Target** output

The firmware emits **CoT XML** (<event version="2.0" type="u-d-c-c"> with lat/lon, callsign, "Detected", 100-800 m range-ring ellipses) — it can feed detections straight into **ATAK**. The unit is a networked sensor node, not just a local alarm.